The CDPD Financials Compliance Audit - Code of Conduct

(Employee's use of social media)

Mohsen Alipour

Cyber Security Student at Collin College – BAT Program

Prof. Akanni Gbolahan - Information Assurance – CYBR-4340.201

---------- **Contents:** ----------

Abstract……3
Introduction……..……3
Who Is CDPD?…….……...…..……3
Who Is DISAG?……3
Steps In An Audit .....……4
Literature……..……...……4
Importance Of IS Audit……4
Who Does The Audit?..……5
Ethics In Auditing……5
Audit Focus…..……6
DISAG Audit Focus……6
Audit Process……...……7
Type: Compliance Audit..……...……7
Audit Subject……...……7
Audit Objective and Scope…….....……..……8
Pre Audit Planning……..……8
Project Statement ……...……9
Fieldwork/The Procedure Conducted…..……9
Findings, Reporting, and Recommendations…….……10
Findings & Reporting……..…..……10
Recommendations…….……...……11
Security Policies, Standards, and Procedures …….……..……13
Social Media Policy……..……16
Definitions and Terms…….……18
References……..……19

---

1 ABSTRACT

Information systems are not just a crucial component of any organization, they are also necessary for its continued survival. There will be no trust in that firm without a secured platform, data protection safeguards, and accountability. A company's clients are its primary source of income. Because of this, no business can thrive without trust, in case of such failure, clients will either minimize their transactions or may quit. The auditor's objective for CDPD Financial is to examine the system's operation and adherence to the company's stated guidelines for workers' usage of social media and its code of conduct. To make sure they are upholding the trust of their clients, CDPD requested this service. The regulations and policies that were adopted will be observed and examined during this audit process, and their conformity with the employees' actions will be contrasted.

2 INTRODUCTION

Who is CDPD?

Consumers in Denton County, Texas can access banking services from CDPD Financials, a financial organization that shares banking's objectives and dedication to meeting and surpassing customers' financial needs. The security of the financial data and clients' personal information has been their top priority.

Who is DISAG?

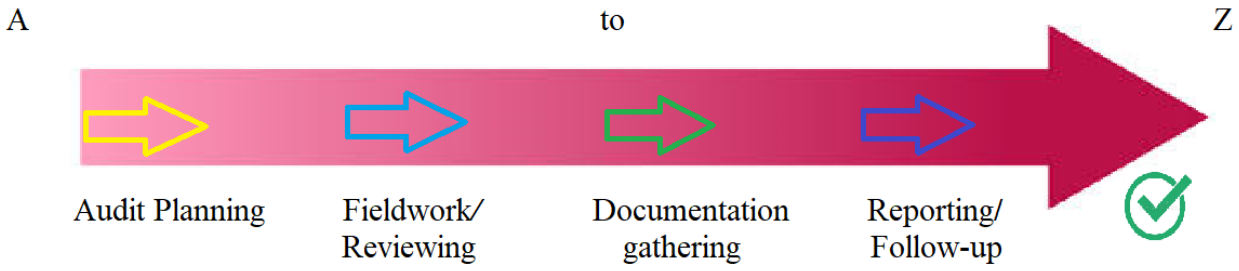
For any professional audit needs in the state of Texas, the third-party auditing missions are expertly handled by us, the DISAG - Denton Information System Auditing Group. In order to determine whether a business is up to its standards, and its defined policies, we are here to help. The audit process is a well-planned step-by-step procedure to address the

need in a timely manner done by the top-notch auditor from our team. They will collect evidence, analyze the internal control system's weaknesses and strengths based on the data obtained through audit assessments, and present an unbiased independent audit that discloses flaws and makes recommendations to stakeholders so that our audit will serve as a guarantee that the business is operating efficiently.

Steps In the Audit Process:

The audit plan will specify the scope, targets, and procedures that will be used to compile the necessary paperwork in order to create and maintain correctly implemented assessments once the audit aim has been explicitly defined and accepted. We can conduct a routine audit process as long as the primary phases are observed.

Table 1: A normal audit process phases



3 LITERATURE

The Importance of IS Auditing:

Information and data protection is necessary for information system security, technological stability, and IT security. False pledges made by current teams or cybersecurity services and owing to a false sense of security are primarily to blame for the success of a company from external bad actors or internal disgruntled employees.

They will target or take advantage of the weakest connections, including individuals and strategies like social engineering. To ascertain whether their operational strategies and technological infrastructure are susceptible to cybersecurity risks, business firms might execute an IS audit. Once we understand the importance of an IS audit, the Client will look for a reputable cybersecurity specialist like DISAG to evaluate the company's strengths and vulnerabilities.

Who Does the Audit?

An audit department is crucial to the outcome of an audit. Major enterprise organizations set up an internal security audit department to do the same duty. Smaller businesses would choose a security consulting firm from the outside to design and oversee an audit program. However, due to legal and regulatory obligations, a certified, independent external body must perform third-party audits like us DISAG- in addition to the internal security audit department.

Ethics of Auditing

An ethical audit is a check of systems or processes for compliance with ethical standards. It assesses how well or poorly an organization complies with the moral requirements of its industry or society. Its purpose is to investigate a company's operations in depth in order to determine how well it adheres to its own regulations, as well as any applicable external regulations and those nationally recognized ethical norms. The purpose of the ethical audit is to ensure that the company's code of conduct, written policies, procedures, and other recommended behaviors are followed in practice. Employee behavior and a company's value statements should be aligned with the business goals and not conflict

because doing so could set a bad precedent and violate the ethics policy. We at DISAG are famous to do our job ethically and thoroughly for 20 years.

4 AUDIT FOCUS

DISAG Audit Focus:

Social media usage on corporate-owned devices has generated debate. The IT and InfoSec managers have also been quite concerned about their employees' interactions on social media platforms, as well as sharing their thoughts about their work environments and experiences using the company devices. By assessing how they are complying with their Code of Conduct and social media use policy, business stakeholders are seeing the need to monitor and put the proper safeguards in place to prevent any potential harm to the business goals. CDPD Financials has established a corporate policy for enterprise information security and part of their code of conduct has a section on the Employee's use of social media. Our Auditors are evaluating the compliance of the employees utilizing that policy as a reference to find any contrast. CDPD recognizes that the Internet provides unique opportunities to participate in an interactive discussion and share information on a particular topic using a wide variety of social media, such as Facebook, LinkedIn, Twitter, Instagram, Snapchat, Pinterest, blogs, and wikis, however, employees use of social media can pose a risk to CDPD financial and its client confidential and proprietary information. Reputation and brand can expose the company to discrimination and harassment claims and can jeopardize the company's compliance with business rules and laws.

5 AUDIT PROCESS

Type: Compliance Audit

This kind of audit is carried out to ascertain the extent and degree of conformity with a law, regulation, standard, or internal control. The compliance audit may need to be carried out by approved or licensed external auditors if a specific law or standard mandates one. For instance, a PCI audit must be carried out by a licensed QSA, and a financial audit of a U.S. public company by a public accounting firm (qualified security assessor). However, even if the statute or standard does not clearly call for audits, the organization may still decide to conduct occasional or ongoing audits to assess its degree of compliance with the law or standard. Preparation for a successful audit is an important part of ensuring compliance with applicable laws, regulations, and standards.

Audit subject

As auditors, we are going to visit and examine the level of use and compliance of the employees of the CDPD financials on the use of company-owned devices. Including their interactions online (while at work) with potential business competitors or possible scenarios in which the employee unknowingly could be socially engineered to give up internal information. It may be that certain bad actors would use sophisticated bullying methods to challenge a target employee for the sole purpose of extracting business information. They can use social media as a stepping-stone to get to that phase of exploitation. We are going to observe and evaluate all the above possibilities by reviewing the logs from the company servers and doing an investigation on publicly posted comments by the employees to find out whether any of the policies regarding the

Code of Conduct has been violated and if so how to mitigate them with appropriate recommendations.

Audit objective and scope:

Regular audits will enable the discovery of new vulnerabilities and enable all staff to adhere to the protocols. The company's compliance with the standards and evaluation of the efficacy of the controls are the key goals of this audit. The objective of the Audit is to determine whether any of the financial information belonging to the customers of CDPD Financials has been shared or the customer account info or identities have been disclosed or discussed online for the employees of the CDPD main field office; if so, to what extent it has been and what ramification it may cause for the business if not corrected.

Pre-Audit planning:

The following are the procedures that DISAG will follow to complete the duty of conducting a compliance audit and thorough evaluation of the Code of Conduct on social media for CDPD finance employees:

- Planning to review the CDPD IT security policy.
- Reviewing the HR employee code of conduct policy.
- Reviewing the Social Media policy.
- Reviewing the employee's security training policy and records.
- Reviewing the HR reports -Violation of code of conduct (if any).
- Collecting the proxy server logs and the user's Internet browsing history.
- Scheduling meetings with the HR manager.
- Reporting the findings and providing recommendations/Remedies.

Project Statement:

Prepares and executes the audit in order to collect enough pertinent information to support our findings and conclusions based on our auditing objectives. According to the goals of our audit, we believe that our data provides a strong basis for the findings and analysis. In order for us to elaborate on a Compliance Audit successfully, it is necessary that we have a solid understanding of the COBIT, ISACA standards, and ethics. We also had to know how the financial firms do business, integrate security into that process, and identify any potential risk areas.

Fieldwork: The procedure conducted:

As has been indicated in the pre-audit planning, we went through all those steps and recorded the answers, created a series of system logs, and carried out Q&A with the HR manager about certain concerns they had. The network access permissions were examined by the auditor; the result shows the configurations were set properly. Per the information collected from their network technician's logbook, their Network Access Management settings had changed a few times within the past four months which was due to certain network expansions (as recorded). With respect to the physical security measures for the main office, the auditor has found nothing out of ordinary. Their after-hour physical access for going back to the office was recorded properly which was following their enterprise information security policy (EISP) and standards. Employee training records were current as they should be. In a few cases, the auditor found a couple of cases in which the employees have not completed their training or still showing "In progress". Additionally, the auditor has received the HR internal record showing some violations of the code of conduct from the past year. It was mostly behavioral incidents

and not related to the scope of this audit, so there was no point of major concern when our team reviewed the HR manager's incident report on that. After analyzing the evidence, logs, and interviews, the auditor reviewed policies, processes, and supporting paperwork as indicated on pages 13 through 17 of this report. He examined the governance over the CDPD financials information systems and data; the consultant identified that only a few of the employees were in violation of the policy pertaining to the social media and code of conduct within the past year while using company-owned devices for that matter.

6 FINDINGS, REPORTING & RECOMMENDATIONS:

Findings & Reporting:

Through the pre-audit process, we were able to identify areas of the organization that we should focus on during the actual audit. Overall, the pre-audit was a success, and we were able to use the findings to improve the outcome of the actual audit.

After reviewing the records of seventy CDPD employees regarding their compliance with the business policies and procedures, the training record has indicated that only four people out of seventy in the main office have not completed their training and it is past due. Only six out of seventy employees got identified as new hires (within 6 months) those who disregarded social media policy and their name was recorded for further training and re-learning the company's policy. One person out of the six employees mentioned above has been red-flagged in many cases. John Doe, one of the new staff hired early this year; after reviewing some of his controversial social media posts on Twitter, indicated that he has the capacity to be involved in speaking inconsiderately

online about CDPD customers and what he might see as business shortcomings. Based upon his recent conversational pattern online, not only some affluent clients of the CDPD have raised concerns, but other employees witness such mannerisms continue while he is meeting his clients face-to-face. Per the HR report, John's direct supervisor noted that his outgoing personality, eagerness to participate in open conversation, and voicing out his mind are not necessarily bad traits, but some conservative-minded customers have expressed their concerns to her as well. Per the IS training records, john's name was listed as "In progress/not completed" for the code of conducts training. While diving deeper, the auditor reviewed the proxy server logs and John's internet browsing history to examine whether John had been under any conflict of interest or such influence willing to hurt the business or not. Auditor identified that a few of his Tweets in the last month have been viewed vastly by the public, commented on, and retweeted, perceived as a formal stance of CDPD Financial on a certain topic, and had challenged the business's core value.

The C-level in management had been alerted to that fact and they had to release an urgent statement distancing themselves from John's comments, by explaining that was his opinion and is not reflecting the point of view of the CDPD and its business philosophy.

Recommendation:

To minimize these business and legal risks, to avoid loss of productivity and distraction from employee's job performance, and to ensure the company's IT & communication systems are used appropriately as explained, employees are expected to adhere to the

guidelines and rules regarding social media use. Compliance with the policy should be mandatory for all employees, including contractors, and vendors providing services to the company. Failure to comply with the social media policy may lead to disciplinary action up to and including termination as has been published by the CDPD. Employee training plays a major role in favor of business needs, so based on our findings, we highly encourage the HR manager to implement a better and stricter strategy to oversee policy compliance routinely and decide how to monitor the progress of their employee's learning curve. Any exceptions to such strategy and policy should be documented and reviewed prior to approval from the CISO of the company, associate general manager, and corporate security council.

7 Security Policies, Standards, and Procedures:

Purpose: The purpose of this policy is to establish standards and expectations regarding any use of social media, using the CDPD information system. Regarding CDPD financials regardless of the equipment used, CDPD Financials is committed to its customers, its employees, and the shareholders of this company, all of which make CDPD financial aid, a great and trusted company. This policy is designed to foster the development and interaction of employee use of social media which adheres to the goals and values of CDPD financials. This company fully respects the legal rights of our employees, and in general, what you do on your own time is your affair, however, activities in or outside of the workplace that affect your job performance, the performance of other CDPD employees, or reflect on CDPD financials business interests or customers are the primary focus of this policy.

- **The computer system is company property**. The computers and other equipment that employees are provided or have access to for work and the email system or the property of the company and have been provided for use in conducting company business only all communication and information transmitted by received from creating it or a store in its information system whether through word processing program, email the Internet or otherwise our company records and property of the company.
- **No expectation of privacy**. The company has the right, but not the duty for any reason and without the permission of any employee to monitor any and all the aspects of his information system, including without limitation reviewing documents, email instant messages, and voice male create it in the store on its information, system deleting any

matter, stored in its system, monitoring site visited by an employee or on the Internet monitoring chat and use group reviewing material download it or uploaded by the user from the Internet and reviewing email sent and received by users. An employee should not have an expectation of privacy in anything they create a store sent or received on the company information system.

- **Professional use of information systems required other policies to apply.** Employees are reminded to be courteous to other users of the system and all ways to conduct themselves in a professional manner, the company's policy against discrimination and harassment, whether sexual or otherwise applies fully to the information system, and any violation of that policy is ground for discipline up to and including discharge.
- **Offensive and inappropriate material illegal activities.** Company policy prohibits using the company's information system to send or receive messages or files that are illegal sexually explicit, abusive, offensive, or the recipient or profane.
- **Solicitations.** The information system may not be used to solicit for religious or political causes commercial enterprises, outside organizations, or other activities, not related to an employment service to the company.
- **Conflicts of interest.** A conflict of interest may arise in any situation, in which employee loyalties are divided between the business interest that to some degree are incompatible with the interest of the company. All such conflict should be avoided the company demand absolute integrity from all its employee and will not tolerate any conduct that falls short of that standard the company expects that no employee will knowingly place himself or herself in a position that would have the appearance of being or could be construed to be in conflict with the interest of the company.

- **Compliance with the code of conduct.** All employees have a responsibility to understand and follow the code of conduct. In addition, all employees are expected to perform their work with honesty and integrity in any areas, not specifically addressed by the code of conduct a violation of this code of conduct may result in appropriate disciplinary action, including the possible termination from employment with the company without additional warning. The company is strongly encouraging dialogue among employees and their supervisors to make everyone aware of the situation that gives rise to ethical questions and to articulate acceptable ways of handling those situations. In addition, each officer and supervisory employee of the company has an obligation to apply and enforce this code of conduct in his or her dealing with subordinates. The code of conduct reflects general principles to guide the employees in making ethical decisions and cannot, and it's not intended to address the very specific situation as such, nothing in this code of conduct prohibits, or restrict the company from taking any disciplinary action On any matter, pertaining to employees conduct, whether or not, they are expressly discussed in this document, the code of conduct is not intended to create any expressed or implied contract with any employee or third-party. In particular, nothing in this document creates any employment contract between the company and any of its employees. The Board of Directors of CDPD Financials has exclusive responsibility for the final interpretation of the code of conduct. The code of conduct may be revised changed or amended at any time by the Board of Directors of the company.
- **Changes to the policy.** The CDPD Financials reviews this policy annually and update policy as necessary and appropriate to ensure its continued effectiveness, taking into

consideration developments in applicable law changes in the regulatory environment the nature of the company's business, and evolving statewide business standards.

Social Media Policy:

- **The guiding principle in regard to CDPD Financial on social media:**

  CDPD financial recognizes that the Internet provides unique opportunities to participate in an interactive discussion and share information on a particular topic using a wide variety of social media, such as Facebook, LinkedIn, Twitter, Instagram, Snapchat Pinterest, blogs, and wikis, however, employees use of social media can pose a risk to CDPD Financial and its client confidential and proprietary information. Reputation and brand can expose the company to discrimination and harassment claims and can jeopardize the company's compliance with business rules and laws.

- **Speaking on behalf of CDPD financial.** Your social media activities are potentially for reaching forms of communication that can be seen by a vast public audience. Unless you have been authorized in writing by a general manager or officer of CDPD financials to speak on behalf of this company in any social media communication, you are prohibited from doing so and agree to never claim to be speaking on behalf of CDPD or claim to be asserting official company position regarding any topics. It should be clear from your postings and your demeanor, on social media, that your opinion expression is our own, and not necessarily those of CDPD Financial, if there is any doubt, you must expressly state, and explained that you are not speaking on behalf of CDPD financial.

- **Ethical conduct.** You agreed that while using social media from work on a computer, you would not conduct activities that are illegal or contrary to the goals and core

values of the CDPD financials code of conduct. You should not engage in unprofessional conduct or behavior any harassing, threatening, menacing, offensive, or abusive conduct communicated through social media is prohibited.

- **Protection of confidential information.** You agreed to protect the CDPD financials' confidential and sensitive information when engaging in social media activities as this information represents one of CDPD's most important assets. It is never appropriate to share post publish or otherwise disclose confidential information, including any information about CDPD customers. You must understand and respect securities and financial disclosure laws and must not disclose any confidential information that may be considered financial information (such as earning future business performance business plans and prospects). CDPD Financials' confidential information includes but is not limited to its source code, internal memorandums, customer lists, fees, products, roadmaps, business plans, employee photos and information, videos, internal audio recording, education on training, contracts policy, and procedure.

  Reference to customers. Do not cite nor reference on social media any CDPD financial clients, customers, partners, or suppliers without their knowledge in approval.

- **Social Media and Networking Sites.** CDPD Financials controls and at its sole discretion, employee access to specific publicly available social media outlets from CDPD resources. An exception to a particularly restricted outlet may be made by the CDPD, at its sole discretion, for approved business needs if such access furthers companies, interests, or the professional business need of the company's employees.

Remember, when using and interacting with social media of any type, common sense, and common courtesy go a long way.

Definitions and terms:

Insider risk: is the potential for an individual who has or had authorized access to CDPD assets to use this access to act in a way that could negatively affect the organization, (whether it's malicious or unintentional).

Information system: A discreet set up of electronic information, resources organized for the collection processing maintenance use sharing, dissemination, or disposition of electronic information as well as any specialized system, such as industrial process, control systems, telephone switching, and private branch exchange systems, and environmental control system.

Mobile device: Portable computing and communications device with information, and storage capability, for example, notebook, laptop, computers, tablets, smartphones, cellular telephones, digital cameras, and audio recording devices.

Risk: A measure of the extent to which an entity is threatened by a potential circumstance or event, and typically a function of the adverse impact that would arise, if the circumstance or event occurs, and also the likelihood of occurrence. Information system-related security risks are those risks that arise from the loss of confidentiality, integrity, or availability of information or information systems and consider the adverse impact on organizational operations, including mission function, image, or reputation, organizational assets, individuals, and other organizations in the nation.

Security event: is a successful or unsuccessful attempt to gain unauthorized access to disrupt or misuse CDPD financial information system or information stored on such information system.

Security incident: is a violation or eminent threat of violation of CDPD financial security policy acceptable use policy or standard security practice.

Social Media: Outlets, such as websites, mobile applications, forms, wikis, blogs, microblogs, and other digital and electronic channels established for networking, sharing, socializing, and other interactions and connections for example, but not all-inclusive Facebook, LinkedIn, Instagram, Reddit, TikTok, Snapchat, and Twitter.

References:

- *FFIEC information, technology, examination, handbook, information, security, September 2016*

- *NIST special publication, 800–53, revision four, security and privacy controls of federal information, security, and organizations*

- *Access Control Policy and Implementation Guides." NIST, CSRC, 2 Dec. 2022, www.csrc.nist.gov/Projects/Access-Control-Policy-and-Implementation-Guides*

- *"Charter: Information Security Committee." St. Lawrence University, 7 Nov. 2022, www.stlawu.edu/it/charter-information-security-committee.*